

알리오

국민과 임직원에게 신뢰받고 사회적 책임을 선도하는 감사

특정감사 결과보고

(고객정보 및 디지털 기기 관리실태 점검)

2024. 2.

목 차

I . 감사 개요	1
1. 감사 배경 및 목적	1
2. 감사중점 및 대상	1
3. 감사 방법	1
II . 처분요구서	2

I 감사 개요

1. 감사 배경 및 목적

우리 회사는 카지노, 호텔 및 레저 등 오프라인 영업과 더불어 온라인플랫폼으로 필요한 고객정보를 서비스 및 법적의무 준수를 목적으로 수집함으로써 처리하는 개인정보의 양과 종류가 지속적으로 증가하고 있는 바,

이에 이번 감사에서는 고객정보의 침해·유출을 예방하기 위한 조취권한 최소화 및 시스템 개선 사항 등의 대책을 점검하고, 고객정보 침해 위험요소 등 문제점을 사전에 제거하여 고객정보 보호와 고객 서비스 안전을 확보하는데 기여하고자 한다.

2. 감사중점 및 대상

이번 감사는 고객정보 관리 및 디지털 기기 도입·운영 등과 관련한 활동 전반을 감사범위로 정하여, 고객정보 및 디지털 기기 관리업무의 위험 요소를 파악하고 발생 가능한 위험을 확인하여 이를 예방함과 동시에 합리적인 해결 방안 및 제도개선 의견을 제시함으로써 기관의 디지털 전환 및 효율성 제고를 위해 우리 회사가 공공기관으로서 준수해야할 개인정보보호 및 정보보안 관련 규정 준수여부에 대해 중점적으로 점검하였다.

3. 감사 방법

우리 회사의 고객정보 관리와 디지털 기기 운영 관련 현황자료를 제출받아 고객정보 보호조치 이행 여부 및 디지털 기기 관리 실태 등을 점검하였다.

II

처분요구서

(주)강원랜드 상임감사위원 통보

제 목 개인영상정보 관리주체 부적정

관 계 부 서 △△△, ■■■■

조 치 부 서 △△△, ■■■■, ○○○○○○

내 용

1. 업무개요

우리회사는 안전사고 및 범죄예방, 모니터링 목적으로 리조트 내 ‘공개된 장소’ CCTV를 설치·운영하고 있으며, 이 가운데 ◆◆◆◆◆◆과 ○○○○○○에서 약 #대, 그 외 약 #대는 ♣♣♣♣♣♣♣, ◀◀◀◀◀, △△△, ■■■■에서 독립적으로 운영하고 있다.

◆◆◆◆◆◆은 카지노 내부 및 그랜드호텔 중요구역 사건사고 예방업무와 중요구역에 모니터링을 목적으로 CCTV 모니터룸을 구축·운영하고 있으며, ○○○○○○은 회사 전체의 재난 대응 및 리조트 안전관리를 위하여 종합상황센터 내 영상보안시스템을 구축하고 총괄적으로 사건사고를 통합 관제하고 있다.

또한 △△△은 그랜드호텔 현관 및 발렛주차장 출입구에 안전사고 및 범죄 예방 목적으로 하고, ■■■■은 ‘◆◆◆’ 영업장 시설물 안전사고 및 범죄 예방을 목적으로 화재 및 안전서비스 등의 업무를 경비용역사를 통해 무인시

시스템으로 운영하고 있다.

2. 관계규정(판단기준)

「개인정보보호법」(이하 “정보보호법” 이라고 한다) 제25조제1항과 우리 회사 「개인정보보호규정」 제18조제1항에 따라 영상정보처리기기¹⁾를 “공개된 장소”에는 원칙적으로 설치·운영할 수 없도록 되어 있으나, 동 규정 제1호부터 제5호에서 정하는 경우에 한하여 예외적으로 [표 1]과 같이 허용하도록 되어 있다.

[표 1] 공개된 장소 CCTV 설치운영을 허용하는 경우

(단위: 대)

구분	내용
1호	법령에서 구체적으로 허용하는 경우
2호	범죄의 예방 및 수사를 위하여 필요한 경우
3호	시설안전 및 화재예방을 위하여 필요한 경우
4호	교통단속을 위하여 필요한 경우
5호	교통정보의 수집·분석 및 제공을 위하여 필요한 경우

자료: 개인정보보호규정 제18조제1항

또한 “영상정보처리기기운영자²⁾”는 「표준 개인정보 보호지침³⁾」 제47조 제4호와 「개인정보보호법」 제25조제6항에 따라 개인영상정보가 분실·도난·유출·변조 또는 훼손(이하 “개인영상정보 침해사고”라 한다)되지 아니하도록 안전성 확보를 위하여 필요한 조치를 취해야 하고 접근권한을 총괄책임자 및 운영책임자⁴⁾ 등 지정된 최소한의 인원으로 제한해야 하고 동법 제7항에 따라 공

-
- 1) 영상정보처리기기란 일정한 공간에 지속적으로 설치되어 사람 또는 사물의 영상 등을 촬영하거나 이를 유·무선망을 통하여 전송하는 일체의 장치로서 시행세칙으로 정하는 장치로서 폐쇄회로 텔레비전(CCTV) 및 네트워크 카메라로 구분되지만 통상 CCTV가 일반적임.
 - 2) 영상정보처리기기 운영자란 법 제25조제1항 각호에 따라 영상정보처리기기를 설치 운영하는 자를 말하며 본 규정에서는 회사로 함
 - 3) 행정안전부 고시
 - 4) 우리회사는 분야별관리책임자(부서장), 개인정보담당자(업무관리자 및 지정자), 취급담당자(최소인원, 부지배인 등)를 지정하여 관리하고 있음

공기관은 영상정보처리기기 운영관리방침⁵⁾을 마련하고 홈페이지에 공개하여야 한다.

그리고 개인영상정보를 안전하게 저장, 전송할 수 있게 암호화 처리를 하여야 하며 개인영상정보를 열람등 요구하는 경우⁶⁾ 열람자, 연락처, 열람목적, 열람한 영상의 생성일시, 거부사유 등을 기록·관리하여야 하고 열람 등 조치를 취할 때⁷⁾에는 정보주체 이외의 자를 명백히 알아볼 수 있거나 정보주체 이외의 자의 사생활 침해우려가 있는 경우 해당되는 정보주체 이외의 자의 개인영상정보를 알아볼 수 없도록 보호조치를 취해야 한다.

또한 영상정보처리기기의 설치·운영에 관한 사무를 위탁하는 경우에는 영상정보처리기기 위탁자의 관리책임자와 더불어 수탁관리자의 명칭 및 연락처를 함께 기재하여야 한다.⁸⁾

따라서 우리 회사는 정보보호법을 준수하기 위한 영상정보처리기기 운영관리 방침을 수립하고 이를 인터넷 홈페이지에 게재하여야 하며 영상정보처리기기 운영자는 개인영상정보 침해사고가 발생하지 않도록 안전성 확보를 위해 조치를 취해야 한다.

3. 감사결과 확인된 문제

그런데 우리 회사의 개인영상정보 운영 실태를 점검한 결과 △△△과 ■■■■은 호텔 내 개인영상정보의 안전성 확보를 위한 조치를 하고 영상정보처리장치를 운영하여야 함에도 접근권한이 없는 자가 취급하거나 암호화 처리가 안 된 USB를

5) 방침에 포함하여야 할 사항(설치목적, 설치대수, 관리책임자, 보관장소, 영상정보확인, 영상정보 열람, 기술적 관리적 조치, 기타 영상정보처리기기의 설치운영 및 관리에 필요한 사항)

6) 표준 개인정보 보호지침 제44조제5항 및 제45조

7) 표준 개인정보 보호지침 제46조

8)개인정보보호법 시행령 제26조제2항, 표준 개인정보 보호지침 제43조제1항

사용하고 보안이 취약한 구역에서 개인영상정보를 수집하는 등 안전성 확보 조치를 맞게 운영하지 않은 사실이 다음과 같이 확인되었다.

가. △△△ 개인영상정보 안전성 확보 조치 미흡

△△△은 그랜드호텔 현관 및 발렛 주차장 출입구 등에 고객의 안전과 범죄 예방을 위해 CCTV를 모니터링 하거나 열람·저장을 위해 현관⁹⁾에서 근무하는 사무실(이하 현관사무실이라고 한다) 내에 모니터실¹⁰⁾을 마련하고 운영하고 있다.

그런데 영상정보저장장치 및 개인영상정보의 안전성을 점검한 결과 「개인정보보호지침」 등의 규정과 다르게 개인영상정보 접근권한이 있는 분야별 관리책임자(△△△장), 개인정보담당자(업무관리자), 취급담당자(부지배인) 등 5명이 외의 근무자가 접근 가능하였고 보안장치가 없는 영상저장 USB 등을 사용하고 있었다.

나. ■■■■ 영상정보처리기기 위탁 관리 미흡

■■■■의 “◆◆◆” 영업장은 2009년 최초 오픈 당시 카지노·호텔과의 CCTV 선로망 연결 시 공사비가 과다하게 발생하는 문제 등으로 ■■■■에서 자체적으로 경비용역을 통해 방범서비스 및 출입통제 서비스 목적으로 현재까지 관리하고 있으며 CCTV #대 및 영상저장장치 등을 설치하여 위탁운영하고 있다.

그런데 ◆◆◆의 영상정보기기의 운영관리 방침¹¹⁾준수여부를 점검한 결과 영상정보처리기기의 설치운영을 위탁한 경우 홈페이지에 ‘수탁자의 명칭 및 연락

9) 현관(Door): 호텔에서 고객 도착할 때 가장 먼저 맞이해주며 차문이나 호텔문을 열어주는 직원이 근무하는 장소

10) CCTV 29개 구역확인 가능: 현관, 도어데스크, 물품보관소, 프론트, 발렛주차장, 전기충전소 등

11) 공공기관은 영상정보처리기기 운영관리 방침을 수립하고 이를 해당기관의 인터넷 홈페이지에 게재하여 정보주체에 게 공개하여야 함.(개인정보보호법 제25조제7항, 시행령 제25조 및 31조제2항제3항)

처’를 함께 기재하도록 되어있음에도 누락되어 있었고 CCTV 운영대수도 실제 #대를 운영하고 있으나 #대로 표기하는 등 사실과 다르게 기재되어 있음을 확인하였다.

개인정보보호법 제29조에 따르면 분야별책임자(■■■장)는 개인영상정보 처리 실태 및 정기적인 조사 및 개선업무를 하여야 하고 영상정보처리기기의 설치운영에 관한 사무를 위탁하는 경우에는 목적 및 의무사항 등 문서로 행하여야 하고 그 사무를 위탁받은 자가 개인영상정보를 안전하게 처리하고 있는 지 관리감독 하여야 했다.

한편 경비구역은 ◇◇◇ 영상정보기기 관리 외 화재감지기 및 도난센서를 부착하고 이상신호가 발생하면 경비구역에 출동하는 업무를 하고 있지만 상황발생 시 ◇◇◇ 업장관리자와 외부기관(경찰서 및 소방서)으로 연락을 하는 절차로 되어있어 영업을 하지 않는 야간, 심야시간에 긴급 상황 발생 시 종합상황센터에서 통제가 어려울 수 있는 것으로 판단된다.

따라서 위와 같은 개인영상정보의 안전성 확보를 위해서는 △△△ 및 ■■■ 등과 같은 영업부서가 아닌 영상정보처리기기를 전문적으로 취급하는 부서 또는 안전총괄부서에서 개인정보보호 관리체계 및 개인정보 및 이용 등에 대한 실태를 점검하고 지속적으로 지도 감독과 함께 운영부서를 지정하여 운영하는 것이 적절하다고 판단된다.

조치할 사항

△△△장은 개인영상정보에 대한 접근권한자 지정 및 보안 저장매체 확인

등 영상정보처리기기의 안전성 확보를 위한 실태점검을 하고, 발렛차량 및 투숙객 전용 주차장 관리 업무 개선 시 ○○○○○과 협의하고 통합적으로 관리할 수 있는 방안을 마련하시기 바랍니다.(통보)

■■■■장은 영상정보처리기기의 안전성 확보 조치에 관한 사항을 영상정보처리기기의 설치운영을 위탁한 경우 홈페이지에 수탁자의 명칭과 연락처를 반드시 게시하시고, 영상정보처리기기 운영 관련하여 ○○○○○과 협의하여 통합적으로 관리할 수 있는 방안을 마련하시기 바랍니다.(통보)

○○○○○장은 영상정보보호 안전성 확보를 위해 △△△과 ■■■ 등 영업공간에서 개별적으로 설치, 운영하는 영상정보처리기기에 대해 통합운영 방안을 마련하시기 바랍니다. (통보)

(주)강원랜드 상임감사위원

주의·권고 요구 및 통보

제 목 업무용 노트북 관리 미흡

관 계 부 서 ○○○○○○○, ★★★★★★

조 치 부 서 ○○○○○○○, ★★★★★★

내 용

1. 업무개요

○○○○○○○은 전사 사무자동화 기기(OA) 등 IT자산관리 업무를 담당하고 업무용 컴퓨터, 노트북 및 태블릿PC를 포함한 전산장비를 도입하여 운영·관리하고 있다.

○○○○○○○에서 도입한 전체 OA장비 중 이동 및 휴대가 용이한 노트북 및 태블릿PC는 #대로 그 중 대여용 #대가 반출되어 부서 또는 개인이 사용 중이고, 유휴장비 #대와 불용대기 #대가 창고에 보관 중이다.

2. 관계 규정 및 판단기준

「IT업무지침」 제9조(IT서비스 운영관리 체계)에 의하면 IT부서장은 투명하고 체계적인 정보시스템 운영 및 응용프로그램·데이터·전산장비·전산기계실 등의 보호를 위해 IT서비스 운영전반에 관한 IT서비스 운영관리 체계를 마련하도록 되어 있고,

「IT자산관리 매뉴얼」 제8조(관리체계)에 따라 IT자산관리부서는 IT자산의 효율

적인 관리 및 운영을 위하여 인프라 IT자산, 사무용 IT자산 등 분류별로 자산운영 담당자를 지정하여 운영하도록 되어 있으며,

동 매뉴얼 제17조(점검 및 조사)에 따라 자산관리담당자와 자산운영담당자는 해당 장비에 대해 주기적인 점검 및 조사를 통해 최적의 상태로 유지해야 한다.

또한 「정보보안 시행세칙」 제66조(단말기 보안)에 의하면 개별사용자는 단말기에 대하여 CMOS¹²⁾ · 로그인 비밀번호의 정기적 변경 사용, 최신 백신 소프트웨어 설치, 운영체제 및 응용프로그램에 대한 최신 보안패치 유지 및 인터넷 파일공유 · 메신저 · 대화방 프로그램 등 업무상 불필요한 프로그램의 설치 금지 등에 해당하는 보안대책을 준수하여야 하며,

정보보호 최고책임자는 개별사용자의 보안대책의 준수여부를 정기적으로 점검하고 개선 조치하여야 한다.

따라서 ○○○○○○은 현업부서가 전산장비를 신청하는 경우 최신 운영체제 업데이트, 보안소프트웨어 설치, 기타 업무용 프로그램 등의 설치여부를 확인한 후 검토하여 지급하여야 하고, 해당 IT자산에 대해 주기적인 점검 및 조사를 통해 최적의 상태로 유지해야 하며,

★★★★★★는 개별사용자의 부팅(CMOS) 패스워드 설정, 백신 등 보안소프트웨어 설치, 게임 및 영화 등 업무무관 프로그램 설치, 개인정보 등 중요정보 관리 등의 보안대책의 준수여부를 정기적으로 점검하고 개선 조치하여야 한다.

3. 감사결과 확인된 문제점

12) CMOS는 흔히 CMOS Setup이라 부르고, 컴퓨터에 어떤 하드디스크가 장착되어 있는지 또는 어떤 그래픽카드를 사용 하는지 등 사용자가 컴퓨터에게 어떤 주변기기들이 장착되어 있으며 어떻게 제어해야 할지 알려 주는 절차이다.

가. 백신 및 윈도우즈 업데이트 관리 미흡

그런데 ○○○○○○은 부서로 지급된 업무용 노트북에 대해 최신 운영체제 업데이트, 보안소프트웨어 설치, 기타 업무용 프로그램 등의 설치여부를 주기적인 점검 및 조사를 통해 최적의 상태로 유지해야 하는데도 지급 후 운영체제 및 백신 업데이트 갱신여부를 점검하지 않았다.

백신소프트웨어는 매년 라이선스가 갱신되어 내부망에 연결된 업무용 PC의 경우 백신 중앙관리 서버를 통해 자동으로 업데이트 되지만 내부망에 연결하여 사용하지 않는 노트북은 백신프로그램을 매년 수동으로 업데이트 시켜야 한다.

따라서 회의용으로 지급된 노트북은 내부망이 아닌 인터넷망에 연결되어 사용을 하므로 백신 및 윈도우즈 업데이트를 하지 않은 채 사용할 경우 랜섬웨어 등 악성코드를 비롯한 각종 사이버 위협에 고스란히 노출되어 자료가 유출되거나 외부부터 탈취될 수 있기 때문에 안전하게 사용하기 위해서는 주기적인 윈도우 및 백신 업데이트가 필수적이다.

나. 노트북 등 이동형 디지털기기 주기적 점검 소홀

★★★★★★는 「정보보안 시행세칙」에 따라 개별사용자의 부팅(CMOS) 패스워드 설정, 백신 등 보안소프트웨어 설치, 게임 및 영화 등 업무무관 프로그램 설치, 개인정보 등 중요정보 관리 등의 보안대책의 준수여부를 정기적으로 점검하고 개선 조치를 하여야 하는데도 부서에 지급된 노트북에 대해 주기적 점검을 소홀히 하였다.

이와 같이 회의 또는 업무용 노트북은 내부망이 아닌 인터넷망에 연결하여

사용하고 백신프로그램 및 윈도우 패치가 최신상태로 업데이트가 되지 않는 등 보안에 취약한 환경인데도 업무관련 자료 및 개인정보를 보관하고 있어 악성 코드 감염으로 보관 중인 자료가 유출되거나 외부로부터 탈취되는 보안사고 위험이 높은 상태이다.

따라서 ○○○○○○ 및 ★★★★★★는 사용자들이 윈도우즈 자동 패치기능 활성화, 방화벽 사용 등 간단한 조치만으로 많은 피해를 예방할 수 있도록 주기적인 점검을 통해 개선조치를 하고 매년 백신소프트웨어 업데이트를 함으로써 악성코드 감염 등 보안 사고를 예방하여야 한다.

조치할 사항

○○○○○○○장은

- ① 일정기간 사용 후 회수 되지 않는 부서에 지급된 노트북에 대해 윈도우 및 백신소프트웨어 업데이트가 장기간 이루어지지 않는 일이 발생하지 않도록 주기적 점검을 철저히 하고, (주의)
- ② ★★★★★★와 협의하여 매년 백신소프트웨어 업데이트를 정기적으로 할 수 있는 방안을 마련하시기 바랍니다. (통보)

★★★★★★장은

- ① 일정기간 사용 후 회수 되지 않는 부서에 지급된 노트북에 대해 정보보안 관련 점검이 장기간 이루어지지 않는 일이 발생하지 않도록 주기적 점검을 철저히 하고, (주의)
- ② ○○○○○○과 협의하여 매년 백신소프트웨어 업데이트를 정기적으로 할

수 있는 방안을 마련하시기 바라며, (통보)

③ 전사 정보보안 점검 시 부서에 지급된 노트북을 포함시켜 정보보안 관련 사항 준수여부 조사 및 점검을 통해 정보보안 사고 발생을 예방하시기 바랍니다.

(권고)